

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

**Headcrab malware is targeting
Redis servers worldwide to mine
Monero**

Date of Publication

February 1, 2023

Admiralty Code

A1

TA Number

TA2023057

Summary

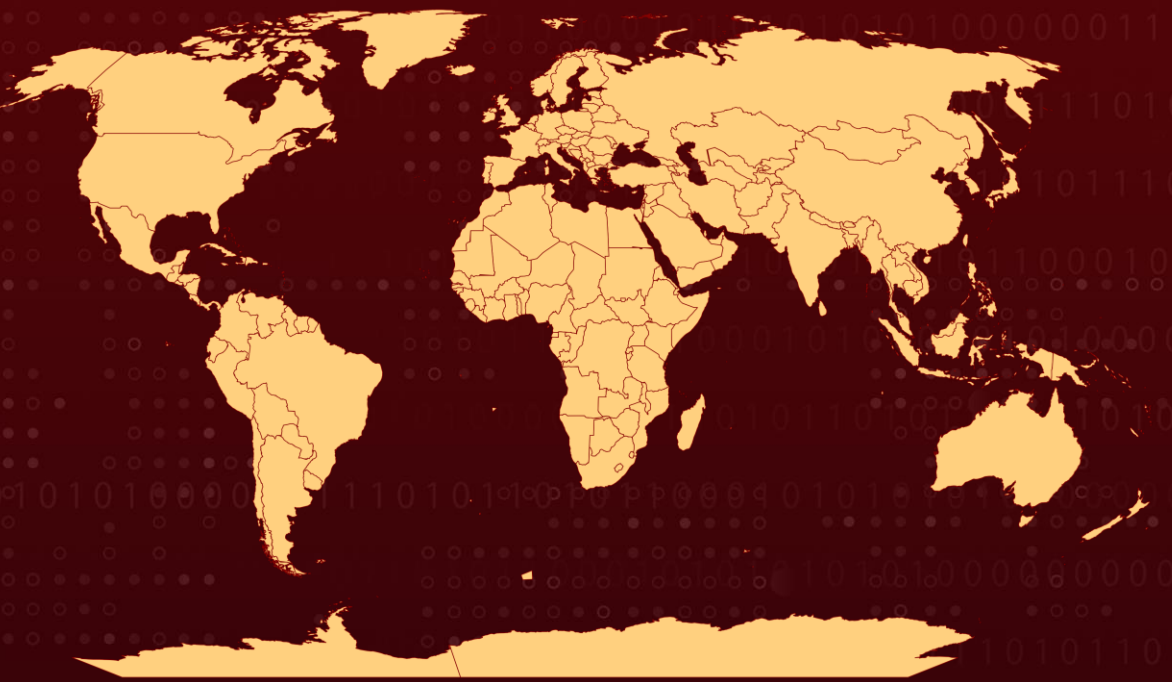
First appeared: September 2021

Attack Region: Worldwide

Affected Product: Redis servers

Attack: A newly discovered HeadCrab malware, designed to target vulnerable Redis servers online, has been able to infect over a thousand servers since September 2021 and has created a botnet that mines Monero cryptocurrency.

🔪 Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

HeadCrab is a new and severe malware that is infiltrating and residing on servers worldwide. It is a custom-made Redis-based malware that is undetectable by traditional anti-virus solutions and has compromised at least 1,200 Redis servers. The malware is initiated when the attacker sets a Redis server as a slave server and downloads a malicious Redis module, the HeadCrab malware, onto the slave server.

#2

The module provides the attacker with full control over the targeted server and is mainly used for cryptocurrency mining. The malware is memory-resident and is not stored on disk, making it difficult to detect. The attacker mainly targets Redis servers and has a deep understanding and expertise in Redis modules and APIs.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation	<u>TA0005</u> Defense Evasion
<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0040</u> Impact	<u>TA0001</u> Initial Access
<u>T1027</u> Obfuscated Files or Information	<u>T1057</u> Process Discovery	<u>T1059</u> Command and Scripting Interpreter	<u>T1190</u> Exploit Public-Facing Application
<u>T1129</u> Shared Modules	<u>T1059.004</u> Unix Shell	<u>T1543.002</u> Systemd Service	<u>T1486</u> Data Encrypted for Impact
<u>T1055</u> Process Injection	<u>T1620</u> Reflective Code Loading	<u>T1036</u> Masquerading	<u>T1036.005</u> Match Legitimate Name or Location
<u>T1033</u> System Owner/User Discovery	<u>T1082</u> System Information Discovery	<u>T1437</u> Application Layer Protocol	<u>T1496</u> Resource Hijacking

Indicators of Compromise (IOCs)

TYPE	VALUE
MD5	c5b992c76b7c9fa3b9bd755dd3b5af76
IPV4	116.202.102.79 178.62.32.29 44.224.209.130 182.74.78.10

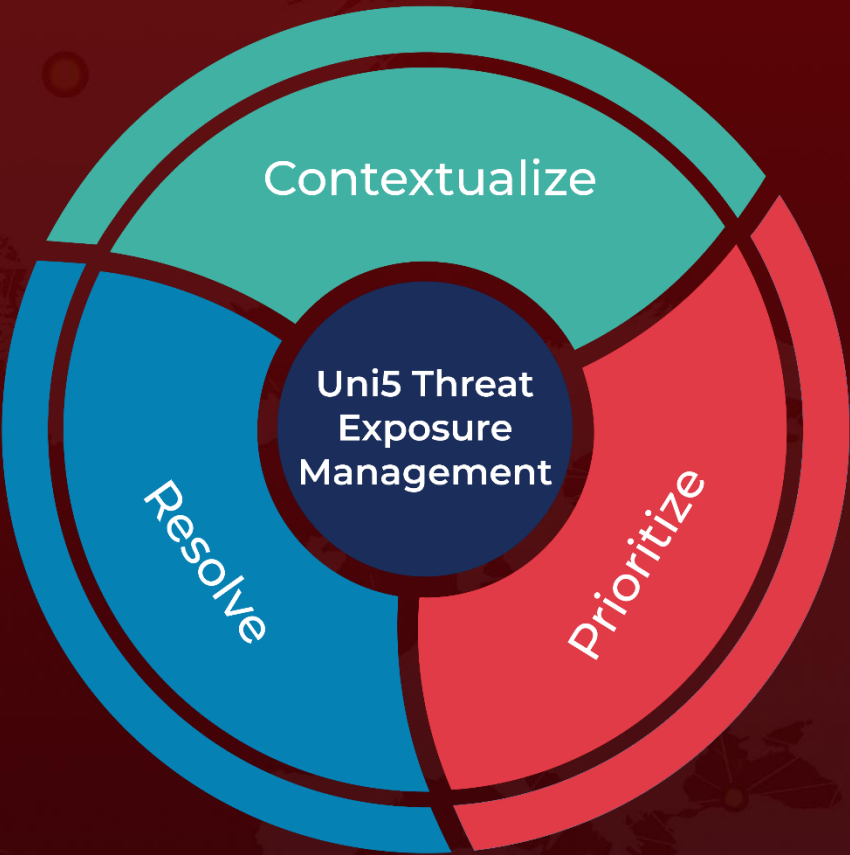
References

<https://blog.aquasec.com/headcrab-attacks-servers-worldwide-with-novel-state-of-art-redis-malware>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

February 1, 2023 • 11:03 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com